Procedimiento de Auditoría Interna, Revisión por la Dirección y Mejora

ISO/IEC 27001:2022 — Cláusulas 9.1, 9.2, 9.3 y 10

Código de documento	SGSI-DOC-010	**Versión**	1.11
Estado	Borrador	**Clasificación**	Confidencial
Propietario	Dirección General — Atalaya GP SL	**Autor**	El consultor (externo)
Fecha de emisión	29/06/2026	**Fecha de aprobación**	Pendiente
Aprobado por	Pendiente conforme a DOC-002 §4	**Registro de aprobación**	Sin acta de aprobación de esta revisión. No acredita implantación ni firma contractual.

Historial de versiones

Versión	Fecha	Autor	Descripción del cambio
0.1	29/06/2026	El consultor	Emisión inicial; diseño de la evaluación del desempeño y la mejora para el primer ciclo
1.0	03/07/2026	Comité de Seguridad Convergente	Aprobación del documento
1.1	24/07/2026	El consultor	Alta de §4.1 (hallazgos de diseño) y de la deuda de diseño como entrada de la revisión (§3.1). Ver decisiones.md §14.
1.1	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.1.
1.2	24/07/2026	El consultor	Verificación periódica de controles como entrada de la revisión (§3.1); alta de HD-04 y HD-05.
1.2	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.2.
1.3	24/07/2026	El consultor	Concreción de la verificación técnica mediante el validador (§3.1); actualización de HD-01.
1.3	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.3.
1.4	24/07/2026	El consultor	Reformulación de HD-02 y ampliación de HD-04. Ver decisiones.md §19.
1.4	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.4.
1.5	24/07/2026	El consultor	Corrección del alcance de HD-04 (cinco escenarios sin interfaz, no cuatro).
1.5	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.5.
1.6	24/07/2026	El consultor	Alta de §2.3 (medición, 9.1) y del Anexo B (mapa de

Versión	Fecha	Autor	Descripción del cambio
			cláusulas 4-10). Ver decisiones.md §21.
1.6	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.6.
1.7	20/08/2026	El consultor	Reclasificación a Confidencial (SGSI-DOC-002 §5) y alta de HD-07. Ver decisiones.md §16.
1.7	20/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.7.
1.8	20/08/2026	El consultor	Recorte del historial de versiones a una línea por entrada, con referencia a decisiones.md donde procede. Sin cambios de fondo.
1.8	20/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.8.
1.9	20/08/2026	El consultor	Alta de HD-08 (§4.1): el MSP opera como encargado del tratamiento de facto (correo M365, NAS, CCTV) sin contrato conforme al art. 28 RGPD. Reflejado también en SGSI-REG-006 v1.6. Ver decisiones.md.
1.9	20/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.9.
1.10	20/09/2026	Autor del caso	Revisión de coherencia de septiembre. Deltas y verificación en docs/fase1-iso27001/correcciones_2026-09.md. Sin cambios en la fecha de corte.
1.11	27/09/2026	Autor del caso	Revisión por dominios aplicables y alcance de controles. Corte 24/07/2026 conservado. Aprobación pendiente. Deltas: revisión 2026-09-27.

1. Objeto y principio

Define cómo se audita el SGSI, cómo la dirección lo revisa y cómo se gestionan las no conformidades y la mejora. Es un documento de diseño: establece el programa y los procedimientos del primer ciclo, cuyas primeras ejecuciones están planificadas y aún no realizadas. Sus registros (informes de auditoría, actas de revisión, acciones correctivas) existirán cuando existan; este procedimiento garantiza que, cuando ocurran, ocurran con método.

2. Evaluación del desempeño: auditoría interna y medición (cláusulas 9.1 y 9.2)

2.1 Programa de auditoría

Elemento	Diseño
Frecuencia y alcance	Una auditoría interna por ciclo anual que cubre el SGSI completo, con énfasis proporcional al riesgo: los procesos que tratan escenarios de nivel Alto y Crítico (verificación de órdenes, terceros y círculo, convergencia físico-digital) se auditan con profundidad; el resto, por muestreo.
Independencia	Con una estructura de nueve personas no existe independencia interna posible: la auditoría se externaliza a un auditor cualificado sin participación en la implantación (coherente con el control A 5.35). El consultor implantador no puede auditar su propio trabajo.
Criterios	ISO/IEC 27001:2022, la documentación del SGSI vigente y los criterios de aceptación de

Elemento	Diseño
	riesgo de SGSI-DOC-004 §4.4.
Primera ejecución	Planificada para el primer semestre de 2027, cuando los controles del plan de tratamiento hayan tenido tiempo de operar: auditar en el mes uno solo certifica papel.
Salida	Informe con hallazgos clasificados (no conformidad mayor / menor / observación / oportunidad de mejora), presentado al Comité. Las no conformidades entran en el registro de la sección 4.

2.2 Reglas del programa

- El auditado nunca elige qué se audita: el plan anual lo aprueba el Comité a propuesta de la Dirección General. El programa, su planificación y los informes de cada auditoría se conservan como información documentada del SGSI conforme a SGSI-DOC-002, porque la cláusula 9.2.2 exige la evidencia del programa además de su ejecución.
- La familia no se audita; se auditan los procesos de Atalaya que la protegen. Las interfaces con la familia se verifican del lado de la organización (¿existe el acuerdo?, ¿funciona el canal?), nunca entrando en la vida de las personas.
- Los resultados de la verificación técnica independiente anual (DOC-006 §5) son insumo de la auditoría, no su sustituto, y aquellos con relevancia de correlación se derivan además al cuaderno único de indicios (SGSI-DOC-009 §5): una prueba técnica dice si un control funciona; la auditoría dice si el sistema funciona. Ninguna de las dos es la verificación periódica de controles de SGSI-DOC-004 §6: esa la ejecuta el propietario sobre su propio control y solo acredita que sigue vigente. Son tres comprobaciones con tres alcances y tres ejecutores distintos, y se nombran separadas precisamente para que no se sustituyan entre sí.

2.3 Seguimiento, medición, análisis y evaluación (cláusula 9.1)

El sistema mide cuatro cosas, y las mide con los medios que ya existen en lugar de crear un cuadro de mando que nadie mantendría. Primero, el grado de cumplimiento de los doce objetivos, con los indicadores definidos en SGSI-DOC-005 §2: lo mide el responsable de cada objetivo, trimestralmente, y lo analiza el Comité en esa misma sesión. Segundo, la cobertura de los dominios aplicables de los escenarios de nivel Alto y Crítico, separando evaluaciones pendientes y cobertura condicionada, mediante la ejecución del validador sobre el registro exportado (SGSI-DOC-004 §6): la ejecuta el responsable del SGSI al cierre de cada plan de tratamiento y antes de cada revisión anual, y su salida se incorpora al acta. Tercero, la verificación en plazo de los controles, contrastando la fecha de última verificación y la periodicidad asignada de cada fila de SGSI-REG-001, hoja «Controles»: la comprueba trimestralmente el propietario de cada control y la consolida el jefe de seguridad. Y cuarto, la ejecución sostenida de los controles de la operativa diaria, con los indicadores de los objetivos O8 a O12: la miden trimestralmente los responsables de esos objetivos, siempre sobre el último trimestre y nunca sobre el mes de arranque, y la analiza el Comité junto con las tres anteriores. De cada medición se conserva su resultado como información documentada conforme a SGSI-DOC-002, porque una medición sin registro no acredita nada y la cláusula exige la evidencia, no la intención. Ninguna de estas cuatro mediciones sustituye a la auditoría interna: la medición produce datos, la auditoría produce juicio sobre el sistema que los genera.

3. Revisión por la dirección (cláusula 9.3)

Anual, en julio, cerrando cada ciclo; extraordinaria tras cualquier incidente S1 o cambio mayor del contexto. Participan el Comité de Seguridad Convergente al completo y, en la parte de conclusiones, el principal, que recibe además el informe ejecutivo (SGSI-INF-001) en lenguaje llano.

3.1 Entradas

Estado de las acciones de revisiones anteriores; tendencias en las no conformidades y en el estado de las acciones correctivas (SGSI-REG-006), incluyendo los incumplimientos documentales ya registrados y distinguiéndolos de auditorías o actuaciones operativas no ejecutadas; resultados del seguimiento y la medición de §2.3, con su evolución respecto del período anterior; cambios en el contexto y en las partes interesadas (SGSI-DOC-001); grado de cumplimiento de los objetivos (SGSI-DOC-005) con sus indicadores; resultados de auditoría y de la verificación técnica —incluida la ejecución del validador de la regla de convergencia sobre el registro de riesgos (SGSI-DOC-004 §6), cuyo resultado se incorpora al acta—; incidentes, indicios y lecciones del período (SGSI-DOC-009 §6); evolución del registro de riesgos y de los residuales aceptados; retroalimentación de la familia a través de la representante de la propiedad; adecuación de recursos; y oportunidades de mejora propuestas; el estado de la verificación periódica de los controles (SGSI-REG-001, hoja «Controles»), con relación expresa de los controles cuya verificación ha vencido y de los escenarios que quedan en cobertura degradada por ese vencimiento; y el estado de la deuda de diseño registrada en la sección 4.1, cuyo cierre o persistencia la dirección debe resolver expresamente.

3.2 Salidas

Decisiones documentadas en acta sobre: oportunidades de mejora aprobadas, necesidades de cambio del SGSI, recursos, y los objetivos del ciclo siguiente. El acta es registro del SGSI y sus decisiones se trasladan al plan de tratamiento o a los documentos afectados con el control de cambios de SGSI-DOC-002.

4. No conformidad y acción correctiva (cláusula 10.2)

Una no conformidad es un incumplimiento de un requisito del SGSI detectado por cualquier vía: auditoría, verificación técnica, indicadores, revisión de registros (p. ej., la revisión mensual de órdenes de DOC-007 R6), o comunicación de cualquier persona. No exige que haya habido incidente: un control que no opera como está escrito es una no conformidad aunque nada malo haya pasado todavía. La regla alcanza también a la verificación: un control cuya verificación no se ha realizado dentro de su periodicidad asignada (SGSI-REG-001, hoja «Controles») es también una no conformidad, pero el requisito incumplido es el de verificar, no el de operar. El control no se reclasifica por ello; el escenario que soporta queda en cobertura degradada hasta que la verificación se realice (SGSI-DOC-004 §6). La distinción no es formal: tratar la falta de verificación como fallo del control degradaría controles que probablemente funcionan y daría a sus propietarios un motivo para no declarar el vencimiento.

Paso	Regla
Registro	Toda no conformidad se anota en el registro de no conformidades y acciones correctivas (SGSI-REG-006) con descripción, origen, fecha y responsable asignado.
Reacción inmediata	Contener y corregir el efecto antes de analizar la causa: primero se cierra la puerta, después se estudia por qué estaba abierta.
Análisis de causa	Obligatorio para toda no conformidad; proporcionado a su gravedad. La pregunta no es quién falló sino qué del sistema permitió el fallo, en coherencia con la regla de no represalia de la política.
Acción correctiva	Dirigida a la causa, con responsable y plazo. Si la causa apunta a un escenario de riesgo mal valorado, obliga a re-evaluarlo (SGSI-DOC-004 §8).
Verificación de eficacia	Toda acción se verifica cerrado el plazo: una acción sin verificación de eficacia no cierra la no conformidad, la esconde.

4.1 Hallazgos de diseño identificados en el ciclo de revisión de julio de 2026 y en la revisión de clasificación de agosto de 2026

El propio proceso de trazabilidad entre el registro de riesgos (SGSI-REG-001) y la Declaración de Aplicabilidad (SGSI-REG-003) ha producido hallazgos antes de que exista auditoría alguna. Se registran aquí porque el sistema los ha generado, no porque un auditor los haya pedido.

La clasificación de cada hallazgo depende del requisito y de su exigibilidad, no solo de la fase del SGSI. Un control planificado aún no exigible no constituye por sí solo incumplimiento; la implantación no aplaza una obligación ya aplicable, como el encargo de tratamiento cuando el MSP accede a datos. Se tratan como deuda de diseño con responsable y plazo, y se elevan a la primera revisión por la dirección. Si al cierre del plazo persisten, entonces sí constituyen no conformidad y pasan a SGSI-REG-006 por la vía de la sección 4. La relación de esta tabla y la de la hoja «Deuda de diseño» de SGSI-REG-006 son la misma: cualquier alta, cierre o cambio de plazo se registra en ambas.

Ref.	Hallazgo	Origen	Tratamiento y plazo
HD-01	Trece controles del Anexo A declarados aplicables descansan en una práctica no escrita, sin documento del SGSI ni control del registro que los soporte: A 5.6, 5.29, 5.32, 6.1, 6.2, 7.5, 7.11, 8.6, 8.7, 8.12, 8.19, 8.21 y 8.23. A 8.7 (protección contra malware) y A 8.19 (instalación de software) se incorporan al cierre del ciclo: figuraban trazados al anexo del proveedor de servicios gestionados, que no regula ninguno de los dos.	Trazabilidad de la SoA v1.1 (columna «Controles»).	Asignar a cada uno un documento o un control del registro, o reclasificar su aplicabilidad con justificación. Responsable: Responsable del SGSI. Plazo: 3 meses.
HD-02	RSC-004 mantiene ambos dominios y carece de medida física; RSC-016 es digital y C-020 es organizativo. La revisión de DOC-004 elimina la exigencia física artificial en RSC-016, pero no acredita cobertura digital ni eficacia.	Verificación de la regla de convergencia sobre el registro v1.1.	Revalidar PT-04/PT-06 y residual. Plazo histórico 24/09/2026; vencimiento pendiente de decisión al revisar. No cierre automático por cambio de metodología.
HD-03	Existen controles físicos contratados y operativos cuya ejecución no deja evidencia registrada, por lo que su eficacia no es verificable (RSC-018). El hallazgo motivó la definición de «cobertura efectiva» en SGSI-DOC-004 §6.	Aportación del jefe de seguridad en la revisión del catálogo de escenarios.	Implantar los registros de ejecución previstos en PT-11 y medir su cumplimiento como indicador. Responsable: Jefe de seguridad. Plazo: 2 meses.
HD-04	Cinco escenarios del registro (RSC-018, RSC-020, RSC-021, RSC-022 y	Verificación cruzada entre SGSI-REG-001 y SGSI-DOC-001 §7.4.	Corregido en dos pasos: alta de cuatro interfaces en SGSI-DOC-001 §7.4, y

Ref.	Hallazgo	Origen	Tratamiento y plazo
	RSC-025) no se situaban en ninguna interfaz declarada del alcance, incumpliendo la regla de completitud de SGSI-DOC-004 §5.1.		normalización de la columna «Interfaz» de SGSI-REG-001 al vocabulario de las diez interfaces declaradas, que hasta la v1.3 del registro empleaba términos propios («Interna», «Externa», «Terceros») no trazables al alcance. Con la normalización, la regla de completitud queda verificable en los dos sentidos. Plazo: 30/09/2026. Cerrado el 24/07/2026. Responsable: Responsable del SGSI.
HD-05	Cuatro escenarios (RSC-003, RSC-012, RSC-022 y RSC-023) carecían de objetivo de seguridad asociado, dos de ellos desde la primera versión del cuadro de objetivos.	Verificación cruzada entre SGSI-REG-001 y SGSI-DOC-005.	Corregido mediante el alta de los objetivos O11 y O12 en SGSI-DOC-005, aprobados por el Comité en la misma sesión. Plazo: 30/09/2026. Cerrado el 24/07/2026. Responsable: Comité de Seguridad Convergente.
HD-06	La Declaración de Aplicabilidad y el registro de riesgos empleaban vocabularios de estado distintos (Implantado / En curso / Planificado frente a IMPLEMENTADO / PARCIAL / PLANIFICADO), y cinco controles del Anexo A figuraban como implantados mientras los controles del registro que los soportan estaban planificados.	Verificación cruzada entre SGSI-REG-003 y SGSI-REG-001 (hoja «Controles»).	Comprobación automática incorporada en check_corpus.py: referencias, estados y excepciones explícitas. Mantener abierta hasta revisión y aceptación del resultado documental. No equivale a eficacia operativa.
HD-07	La clasificación de SGSI-REG-001 (Confidencial) no era coherente con su propio contenido: la portada declara que contiene «la relación completa de vulnerabilidades del sistema de protección de la familia», que es la definición literal de Restringida en SGSI-DOC-002 §5 («su exposición habilita daño directo a personas»), y esa misma	Revisión de clasificación de agosto de 2026, por aplicación de la regla del nivel superior de SGSI-DOC-002 §5.	Reclasificado SGSI-REG-001 a Restringida y SGSI-REG-006 y este documento a Confidencial, en esta misma revisión (REG-001 v1.6, REG-006 v1.5, DOC-010 v1.7). Responsable: Responsable del SGSI. Plazo: 20/08/2026. Cerrado el 20/08/2026.

Ref.	Hallazgo	Origen	Tratamiento y plazo
	sección obliga a aplicar el nivel superior en caso de duda. El mismo desajuste, un nivel más abajo, afectaba a SGSI-REG-006 (hoja «Deuda de diseño») y a este mismo documento en su §4.1: ambos detallan, control a control, qué medida concreta de qué escenario Alto o Crítico no está todavía operativa o verificada, y estaban clasificados Interna.		
HD-08	El MSP administra correo corporativo (M365), NAS doméstico con documentación familiar y CCTV con acceso administrativo pleno (DOC-006 §5), pero no consta contrato de encargado del tratamiento conforme al art. 28 RGPD que regule esa relación. Como consecuencia directa, tampoco consta verificada la región de alojamiento del tenant M365 ni, si procede, las garantías del art. 46 RGPD para una eventual transferencia internacional.	Construcción de SGSI-REG-008 (Registro de Actividades de Tratamiento), tratamiento T-10.	Formalizar contrato o anexo de encargado del tratamiento con el MSP (objeto, duración, obligaciones del art. 28.3, sub-encargados, medidas de seguridad, destino de los datos a la finalización) y confirmar la región de alojamiento del tenant M365. Responsable: Dirección General. Plazo: 20/11/2026.

5. Mejora continua (cláusula 10.1)

Las fuentes de mejora son las salidas de todo lo anterior más las propuestas espontáneas de cualquier persona del sistema, familia incluida. El Comité las evalúa trimestralmente con un criterio único: toda mejora debe reducir riesgo o reducir fricción; las que solo añaden proceso se rechazan por defecto. En una organización de nueve personas, cada regla nueva compite por la misma atención: la mejora que importa es la que hace el sistema más simple de cumplir, no más grueso.

Revisión de septiembre: HD-08 continúa abierto y refleja la falta actual de contrato descrita por el escenario; su plazo de tratamiento no equivale a una exención legal. La conclusión residual de DOC-012 permanece abierta hasta justificarla por riesgo. Se registran asimismo la corrección de dominios C-039/C-044 y las verificaciones documentales de esta revisión en REG-006. Una corrección de texto no prueba eficacia operativa.

Anexo A. Trazabilidad con ISO/IEC 27001:2022

Sección	Cláusula
2.1 y 2.2 — Auditoría interna	9.2.1, 9.2.2; A 5.35
2.3 — Seguimiento y medición	9.1

Sección	Cláusula
3 — Revisión por la dirección	9.3.1, 9.3.2, 9.3.3
4 — No conformidad y acción correctiva	10.2
5 — Mejora continua	10.1

Anexo B. Mapa del corpus contra la norma

Cada documento del sistema lleva su propio anexo de trazabilidad, que dice qué cláusulas cubre. Falta la comprobación inversa, que es la que hace un auditor el primer día: recorrer la norma cláusula a cláusula y preguntar qué documento la desarrolla. Esta tabla es esa comprobación, y se mantiene como artefacto del sistema y no como ejercicio de una revisión: cuando cambie la estructura documental, se actualiza aquí antes que en ningún otro sitio. Su primera versión, en el cierre del ciclo de julio de 2026, dejó al descubierto cuatro cláusulas que ningún documento desarrollaba —9.1, 8.1, 7.3 y 7.1— y una atribuida al órgano equivocado (6.1.3 f).

Cláusula de ISO/IEC 27001:2022	Dónde se desarrolla en este sistema
4.1 Comprensión de la organización y su contexto	SGSI-DOC-001 §4 y §5
4.2 Necesidades y expectativas de las partes interesadas	SGSI-DOC-001 §6
4.3 Determinación del alcance	SGSI-DOC-001 §7: declaración, inclusiones, exclusiones e interfaces
4.4 El sistema de gestión	SGSI-DOC-001 §8
5.1 Liderazgo y compromiso	SGSI-DOC-003 §3, declaración firmada por el administrador único
5.2 Política	SGSI-DOC-003 §4; comunicación y disponibilidad en §7
5.3 Roles, responsabilidades y autoridades	SGSI-DOC-003 §6
6.1.1 Riesgos y oportunidades del propio SGSI	SGSI-DOC-001 §9
6.1.2 Apreciación de riesgos	SGSI-DOC-004 §4 y §5; SGSI-REG-001
6.1.3 a) a e) Tratamiento y Declaración de Aplicabilidad	SGSI-DOC-004 §6; SGSI-REG-002 y SGSI-REG-003
6.1.3 f) Aprobación del plan y aceptación del residual	SGSI-DOC-004 §4.4; SGSI-REG-002, columnas de aprobación del plan y de aceptación del residual por el propietario del riesgo
6.2 Objetivos y planificación para lograrlos	SGSI-DOC-005: doce objetivos con indicador, responsable, plazo y recursos
6.3 Planificación de cambios	SGSI-DOC-001 §8, párrafo final
7.1 Recursos	SGSI-DOC-003 §6.5; detalle del ciclo en SGSI-DOC-005 §2
7.2 Competencia	SGSI-DOC-003 §6.3, incluida la conservación de la evidencia
7.3 Toma de conciencia	SGSI-DOC-003 §6.4
7.4 Comunicación	SGSI-DOC-003 §7, plan de comunicación
7.5 Información documentada	SGSI-DOC-002 completo, incluida la de origen externo (§6)

Cláusula de ISO/IEC 27001:2022	Dónde se desarrolla en este sistema
8.1 Planificación y control operacional	SGSI-DOC-004 §9; procedimientos SGSI-DOC-006 a SGSI-DOC-009
8.2 Apreciación de riesgos: ejecución	SGSI-DOC-004 §5 y §8; SGSI-REG-001
8.3 Tratamiento del riesgo: ejecución	SGSI-DOC-004 §6; SGSI-REG-002
9.1 Seguimiento, medición, análisis y evaluación	Este documento, §2.3
9.2 Auditoría interna	Este documento, §2.1 y §2.2
9.3 Revisión por la dirección	Este documento, §3
10.1 Mejora continua	Este documento, §5
10.2 No conformidad y acción correctiva	Este documento, §4; SGSI-REG-006

Seguimiento 27/09/2026. REG-006 v1.11 conserva HD-02/HD-03 abiertas con vencimientos históricos pendientes de decisión; no se inventa un acta ni una no conformidad ejecutada a otra fecha de corte. HD-09 se reevalúa: RSC-019 físico, RSC-020 ambos con carencia digital. HD-11 sustituye la propuesta externa de exigir físico a RSC-007/RSC-024: estos son digitales; quedan la coacción de RSC-014 y las justificaciones digitales de C-016/C-019, junto con la reclasificación de C-062. HD-08, NC-2026-001 y HD-10 siguen abiertos.